Quarantine Package

Run an npm dependency in a hardened, traced sandbox on Vultr before it ever runs on your machine.

Blast Radius Zero

Vultr Cloud Compute

Vultr Serverless Inference

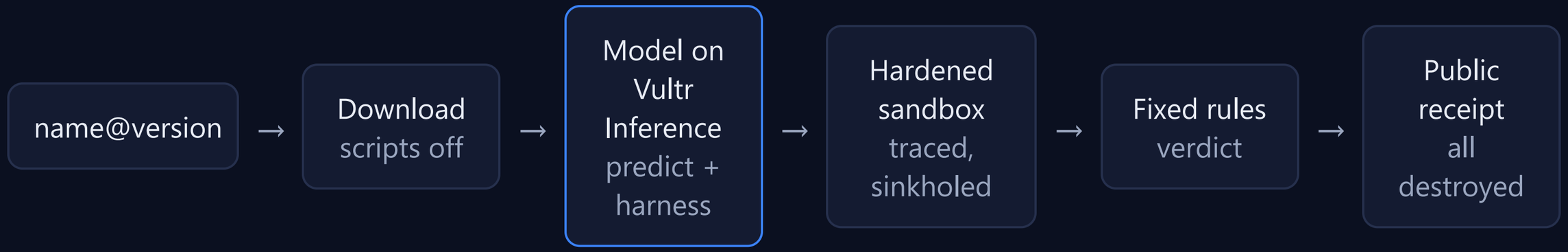
qp.hugovaler.com · github.com/hvaler/quarantine-package · Team Sandbox First

The problem

- Supply-chain attacks hide in **install scripts** and load-time code.
- They read tokens, write to system paths and send data out.
- Reading the code does not tell you what it will do.
- Running it on your laptop, with your secrets in the environment, **is** the risk.

Question every developer should be able to answer in seconds: "*what does this package actually do when installed?*"

How it works



Isolation

Read-only root, cap-drop ALL, non-root, no-new-privileges, pids / memory / CPU limits, hard wall clock.

Observation

Separate tracer follows file, process and network syscalls. The only network route ends at a logging sinkhole.

Decision

Deterministic rules decide. The model predicts before the run and explains after it; a guard rejects any text that contradicts the verdict.

On Vultr

Service	Role
Cloud Compute VM	The whole backend: Caddy (TLS), web app and job queue, Docker with sandbox, tracer and sinkhole containers, receipts.
Serverless Inference	Every LLM call (`mimo-v2.6-pro`). The key stays in a root-only file on the VM: never in a sandbox, log or receipt.

Only ports 80/443 are public. The app listens on 127.0.0.1; the sandbox network is internal, with no route to the internet.

Containment moment

A hostile package's install script tries to:

- write to **`/etc`** and the home directory,
- reach for **`docker.sock`** and credential files,
- **`POST`** data to a collector.

Verdict **`do-not-install`**. Every attempt listed with the rule it fired. The exfiltration only reached the sinkhole; nothing left the VM. The site kept answering, and every container, network and volume was destroyed.

Results on the live deployment

Package	Verdict	Note
`express@4.21.2`	`install`	benign baseline
`fastify@5.12.4`	`install`	real dependency of the author's project, ~9 s
`netbenign (fixture)`	`review`	network attempt, caught by the sinkhole
`hostile (fixture)`	`do-not-install`	writes /etc, exfiltrates to sinkhole
`fork bomb / infinite loop`	`do-not-install`	stopped by pids limit / wall clock

Every receipt is a public page, **Markdown for a PR**, **JSON** and **SARIF** for GitHub code scanning; the CLI exit code gates CI.

Known limitations are documented in the README and in every receipt.

Built and verified

- Developed with **Claude Code** by a band of agents: implementer, adversary, auditor, analyst.
- A human operator dispatched each stage, deployed it and handled every secret.
- Each stage accepted only after an independent auditor reproduced its criteria on a clean clone.
- The adversary agent found a gap in the tracer; the auditor reproduced it; it was fixed and re-verified before release.
- The product's own agent uses **only Vultr Serverless Inference**.

Try it: **qp.hugovaler.com**